

Research Report 2: NMAP

1. What Did You Do

Network Selection and Permission

The network selected for this exercise was my personal home lab environment, a self-administered infrastructure consisting of a Proxmox virtualization server, multiple virtual machines and containers, a NAS, network infrastructure hardware, IoT devices, and general-purpose workstations. Because I own and manage this environment in its entirety, I serve simultaneously as the analyst and the organization granting permission for the scan — no external approval was required.

Installing Nmap

Nmap 7.98 was downloaded from nmap.org and installed on my Windows workstation using the Windows setup installer. The installer includes both the command-line Nmap binary and Zenmap, a graphical front-end. This exercise used the command-line interface, as it provides full control over scan parameters and produces output that can be saved and reviewed.

How Nmap Works

Nmap, short for Network Mapper, is an open-source network reconnaissance tool that operates by crafting and transmitting specific network packets and then analyzing the responses it receives. Understanding how Nmap operates under the hood is important for interpreting its output correctly.

The foundation of any Nmap scan is host discovery — determining which IP addresses on a given range have active devices. By default, Nmap sends an ICMP echo request (a standard ping), a TCP SYN packet to port 443, a TCP ACK packet to port 80, and an ICMP timestamp request to each address. If any response is received, the host is considered alive. This multi-probe approach is more reliable than ICMP alone, because many firewalls block ping while still allowing other traffic. The `-sn` flag performs only this discovery step without proceeding to port scanning, which is useful for quick network inventories.

Once live hosts are identified, Nmap moves to port scanning. The default scan type — and the one used in this exercise — is a TCP SYN scan (also called a half-open scan). In a normal TCP connection, a client sends a SYN packet, the server responds with a SYN-ACK to indicate the port is open, and the client completes the handshake with an ACK. Nmap deliberately does not complete this handshake. Instead, it sends the SYN, waits for a response, and then sends a RST (reset) packet to tear down the connection before it is fully established. If the target responds with SYN-ACK, the port is recorded as open. If the target responds with RST immediately, the port is closed. If there is no response at all (which typically means a firewall is silently dropping the packet), the port

is marked as filtered. This technique is faster and less likely to appear in application-level logs than a full TCP connect scan.

Service version detection, enabled by the `-sV` flag, goes a step further than simply identifying open ports. Once a port is found to be open, Nmap sends a series of protocol-specific probe strings to it and analyzes the responses against a database of known service signatures. For example, it might send an HTTP GET request to an open port and compare the response headers against thousands of known web server fingerprints to determine whether the service is Apache, Nginx, OpenWrt uHTTPd, or another web server — and often identify the specific version number. This matters because version numbers allow an analyst or attacker to look up known vulnerabilities for that exact software release.

Operating system detection, enabled by the `-O` flag, works through a process called TCP/IP stack fingerprinting. Different operating systems implement the TCP/IP protocol slightly differently — they use different initial TCP window sizes, respond to unusual flag combinations in different ways, and set IP TTL values differently. Nmap sends a battery of carefully crafted probe packets and compares the pattern of responses against a database of over 5,000 known OS fingerprints. The result is an OS guess with a confidence percentage. On this network, the Windows Server 2022 Active Directory machine was identified with 97% confidence, while the router running a heavily customized Linux build was harder to fingerprint precisely.

The `-A` flag enables aggressive mode, which bundles several additional capabilities: the Nmap Scripting Engine (NSE), which runs Lua-based scripts to perform deeper probing of discovered services; traceroute, which maps the path packets take to reach each host; and additional OS detection heuristics. The NSE scripts are what allow Nmap to extract detailed information like LDAP domain structure, SMB signing configuration, RDP certificate details, and DNS server identification strings — all of which appeared in this scan's output.

The scan was executed with the following command:

```
nmap -sV -O -A X.X.X.X/24 -oN scan_results.txt
```

The target range `X.X.X.X/24` was derived from the workstation's IP address of `X.X.X.X` and its `/24` subnet mask, which covers all 256 addresses from `X.X.X.X` through `X.X.X.X`. The `-oN` flag saved the complete output to a plain text file for later analysis. The scan ran for approximately nine minutes and identified 32 active hosts.

Analyzing the Output

After the scan completed, I reviewed the saved output file methodically, working through each discovered host in order. For each host, I noted the IP address, the MAC address and its manufacturer (which Nmap resolves using an OUI database), the detected operating system and confidence level, every open port and its state, and the service name and version running on each open port. I cross-referenced MAC address manufacturer codes to help identify ambiguous devices — for example, the Proxmox Server Solutions GmbH MAC prefix appearing on several hosts confirmed they are virtual machines running on the Proxmox hypervisor regardless of what OS is running

inside them. For each finding, I considered what role the service plays and what its presence on the network implies from a security standpoint.

2. What Are the Results

Network Infrastructure

The network gateway at X.X.X.X is a TP-Link Deco mesh router running OpenWrt Linux. Nmap found four open ports: DNS on port 53 running ISC BIND 9.20.19, an HTTP admin interface on port 80 via OpenWrt uHTTPd, HTTPS on port 443 with a TLS certificate issued to tplinkdeco.net, and UPnP on port 1900 via MiniUPnP 1.8. The router is identified as both a wireless access point and a broadband router in Nmap's service classification. As the single point through which all network traffic enters and exits, this device is the most critical piece of infrastructure on the network.

The Pi-hole DNS filter at X.X.X.X runs SSH on port 22, DNS via dnsmasq on port 53 (identified specifically as the Pi-hole fork), and a web administration interface on port 80. The HTTP response headers captured by Nmap's scripting engine revealed strong security configuration: Content-Security-Policy restricting resource loading, X-Frame-Options set to DENY to prevent clickjacking, X-Content-Type-Options to prevent MIME sniffing, and a strict Referrer-Policy. This indicates the Pi-hole installation follows current web security best practices.

Virtualization Infrastructure

The primary Proxmox hypervisor at X.X.X.X runs on Dell hardware and exposes three services: SSH on port 22 using OpenSSH 9.2p1, rpcbind on port 111 (a prerequisite for NFS and other RPC-based services), and the Proxmox Virtual Environment REST API on port 3128. This host is responsible for running all virtual machines and containers on the network and represents one of the highest-value targets in the infrastructure.

Several virtual machines were identified by their Proxmox Server Solutions GmbH MAC address prefixes. The VM at X.X.X.X runs Debian Linux with only SSH open on port 22 using the newer OpenSSH 10.0p2 build. The VM at X.X.X.X runs Ubuntu Linux and exposes SSH on port 22 alongside a NoMachine NX remote desktop server on port 4000 — this host was only visible in the second scan after all VMs were started, confirming it had been powered off initially.

The Active Directory Domain Controller at X.X.X.X is a Windows Server 2022 virtual machine running on Proxmox hardware. Nmap identified it with 97% confidence through OS fingerprinting and discovered twelve open ports: DNS (53), Kerberos authentication (88), Windows RPC (135), NetBIOS name service (139), LDAP (389), SMB (445), Kerberos password change (464), RPC over HTTP (593), LDAP over SSL (636), Global Catalog LDAP (3268), Global Catalog LDAP over SSL (3269), Remote Desktop Protocol (3389), Windows HTTP API for SSDP/UPnP (5357), and Windows Remote Management (5985). The NSE scripts extracted the domain name jakeburleson.me, the computer name WIN-81BJAPND83K, and the complete LDAP directory structure from unauthenticated queries.

The scanning workstation itself at X.X.X.X (identified as host.docker.internal, indicating Docker Desktop is installed) shows five network-accessible services: Windows RPC (135), NetBIOS (139), SMB (445), a MySQL database server on port 3306 flagged as unauthorized, and a NoMachine NX remote desktop server on port 4000.

IoT and Consumer Devices

Two dedicated IoT devices appeared on the network. The GE Lighting device at X.X.X.X runs lwIP, a lightweight TCP/IP stack common in embedded and microcontroller-based IoT hardware. No TCP ports were open or responding, though the device is active and communicating on the network. The Denver Electronics AC-5000W MK2 IP camera at X.X.X.X was positively identified by OS fingerprint. Like the lighting device, no open ports were detected, though its presence on the shared network segment is a meaningful attack surface consideration.

A Nintendo Switch console at X.X.X.X showed all 1,000 scanned ports in a filtered state, meaning a firewall is dropping probe packets rather than responding — standard behavior for gaming consoles. A Samsung device at X.X.X.X, likely a smartphone or smart television based on the MAC prefix, showed the same all-filtered response pattern. The device at X.X.X.X carries a Samsung Electronics MAC address and had a large number of open ports in the truncated portion of the scan output consistent with a NAS running OpenMediaVault.

Wireless, Mobile, Bluetooth, and Cloud Components

Nmap operates at the IP layer and cannot directly distinguish wired from wireless connections, as both appear identically at the TCP/IP level. However, several devices on this network are known to connect via the TP-Link Deco mesh router's 2.4GHz and 5GHz Wi-Fi bands: the Nintendo Switch, the Samsung mobile device, the GE lighting controller, and the IP camera. Each wireless device represents a component of the attack surface that exists outside the physical security boundary of wired infrastructure. Wireless signals propagate beyond the physical premises and can potentially be captured or jammed by nearby devices. If the wireless encryption standard (WPA2 or WPA3) were compromised, an attacker could gain access to the internal network without any physical access.

Bluetooth is a separate radio frequency protocol that does not use TCP/IP and is therefore entirely outside the scope of what Nmap can scan. Despite this, Bluetooth presents a real attack surface on any network where devices have it enabled. Laptops, phones, the Nintendo Switch, and wireless peripherals all maintain Bluetooth radios that may be discoverable or connectable by nearby devices. Known Bluetooth attack categories include BlueSnarfing, which allows unauthorized access to data on a Bluetooth-enabled device; BIAS (Bluetooth Impersonation Attacks), which exploits weaknesses in the legacy secure connection process; and BLESA (Bluetooth Low Energy Spoofing Attack), which targets BLE reconnection procedures common in IoT devices. These attacks do not appear in any IP-layer scan but are part of the overall attack surface of any environment with wireless devices.

Cloud services extend this network's attack surface beyond its physical perimeter. Tailscale VPN is deployed to provide secure remote access to self-hosted services including a Vaultwarden password manager instance. Tailscale creates an encrypted peer-to-peer mesh using the WireGuard protocol and routes connections through its control plane to establish direct tunnels between devices. Because services like Vaultwarden are only reachable through the Tailscale tunnel rather than exposed directly to the internet, their contribution to the external attack surface is significantly reduced. However, the Tailscale control plane itself represents a cloud dependency, and any cloud-synchronized applications on mobile devices — backups, credential managers, email clients — extend the effective attack surface beyond anything visible in the local network scan.

Protocols Identified

The scan identified a range of protocols across the network. At the application layer, these include SSH (Secure Shell) for encrypted remote administration, DNS for name resolution, HTTP and HTTPS for web interfaces, SMB (Server Message Block) for Windows file and printer sharing, LDAP for Active Directory directory queries, Kerberos for authentication ticket issuance, RDP (Remote Desktop Protocol) for graphical remote access, MySQL for database access, NX Protocol for remote desktop sessions, UPnP for automatic port forwarding, RPC (Remote Procedure Call) for Windows service communication, and WinRM for remote management scripting. At lower layers, the network uses TCP as its primary transport protocol for the services listed above, with UDP used by DNS, rpcbind, and ICMP for network diagnostics.

Attack Surface Analysis

The most significant attack surface exposure on this network is the concentration of sensitive services on the Active Directory Domain Controller at X.X.X.X. Active Directory is the authentication backbone of the Windows environment — controlling it means controlling all accounts and access within the domain. The combination of LDAP, Kerberos, SMB, and RDP on a single host creates an extremely high-value target. The exposed RDP port (3389) is particularly notable: RDP has been the entry vector for a large proportion of enterprise ransomware attacks in recent years. SMB (445) is associated with lateral movement exploits including EternalBlue (MS17-010), which was used in the WannaCry and NotPetya attacks. Perhaps most critically, the full domain name, computer name, LDAP structure, and operating system version were all harvested by Nmap without authentication — providing an attacker with a detailed reconnaissance package before any exploitation attempt.

The MySQL database service on port 3306 of the scanning workstation represents an unnecessary network exposure. The Nmap output flagged it as 'unauthorized,' meaning the service is accepting incoming connection attempts but refusing unauthenticated access. However, a database service should not be accepting connections from arbitrary hosts on the local network in the first place. Binding MySQL to localhost (127.0.0.1) instead of all interfaces (0.0.0.0) would remove it from the network-accessible attack surface entirely without affecting any local application that depends on it.

The Proxmox hypervisor management API on port 3128 and the accompanying REST interface present a critical exposure. A compromised hypervisor management interface can create, modify, snapshot, or destroy any virtual machine on the host. In a properly secured environment, this interface would be restricted to a dedicated management VLAN with strict access control lists. On this flat network, it is reachable by every connected device including the IoT lighting controller and the IP camera, which have no legitimate reason to communicate with a hypervisor.

The UPnP service on the router (port 1900) is a known vulnerability. UPnP was designed to allow devices on a local network to automatically configure inbound port forwarding rules on the gateway without requiring authentication. Malware running on any network device, or a compromised IoT device with network access, could use UPnP to punch holes through the router's firewall and expose internal services to the internet without any notification or approval from the network administrator.

The IoT devices — the GE lighting controller and the IP camera — represent a class of attack surface that is systematically underestimated. These devices typically run minimal firmware with long patch cycles, may ship with default or hardcoded credentials, cannot have security software installed on them, and are often forgotten once deployed. Because they share the same network segment as the servers, a compromised IoT device could be used as a pivot point for internal reconnaissance and lateral movement. The camera in particular, with its video feed capability, represents a physical security risk in addition to a network security risk.

The flat network architecture — where all 32 hosts share the same /24 subnet with no VLAN segmentation — is itself an attack surface amplifier. Without segmentation, any compromised device can freely communicate with every other device. A proper segmentation strategy would isolate IoT devices in a quarantine VLAN with no route to server infrastructure, place hypervisor management interfaces on a dedicated administrative VLAN, and require all cross-segment traffic to pass through a firewall with explicit allow rules. This architecture is a foundational requirement in frameworks such as CMMC, NIST 800-171, and the CIS Controls.

The two NoMachine NX remote desktop instances — one on the Windows workstation (X.X.X.X) and one on the Ubuntu VM (X.X.X.X) — add additional remote access vectors to the attack surface. While NoMachine uses encrypted sessions, each remote desktop service represents an authentication endpoint that could be targeted by credential stuffing or brute force attacks if reachable by an attacker who gains internal network access.

3. What Did You Learn

This exercise demonstrated concretely how much information about a network is freely visible to anyone with access to it and a copy of freely available software. Before running the scan, I had a working mental model of what was deployed on my network. After nine minutes with Nmap, I had a detailed inventory including operating system build numbers, software version strings, TLS certificate validity dates, Active Directory domain structure, computer names, and a complete map of every listening service. This

reframing — seeing the network as an attacker would see it on first contact — is one of the most valuable perspective shifts in security practice.

I also learned that attack surface is not simply a count of devices or open ports, but a function of what is running, what is reachable, who can reach it, and how it is configured. The MySQL database on my workstation is a clear example: running a database is not inherently dangerous, but a single configuration choice — binding to all interfaces rather than localhost — quietly added the service to the network-accessible attack surface with no visible indication during normal operation. Without the Nmap scan, this would have gone unnoticed indefinitely. The same logic applies to the Proxmox API being reachable from IoT device addresses.

The exercise reinforced the practical importance of network segmentation in a way that abstract descriptions do not. Seeing the Active Directory domain controller, the hypervisor API, the IP camera, and the GE light bulb all appearing in the same flat /24 subnet makes the risk concrete rather than theoretical. Any of those IoT devices, if compromised, has a direct network path to the most sensitive infrastructure on the network. VLAN segmentation would not be an optional hardening measure in this environment — it would be a foundational security control.

From a career standpoint, this exercise gave me hands-on experience with a tool I expect to use regularly in IT and cybersecurity roles. Network scanning is foundational to multiple security disciplines: it is the starting point for penetration testing, the basis of asset inventory work in compliance audits, a component of vulnerability assessment workflows, and a useful verification tool when confirming that firewall changes had their intended effect. The ability to read and interpret Nmap output is a practical skill that translates directly into job performance in any security operations or infrastructure role.

For an organization applying this methodology, the most immediate value would be establishing a scanning baseline and then scheduling recurring scans to detect changes over time. A single scan is a snapshot; periodic scans enable detection of unauthorized devices joining the network, new services appearing on unexpected ports, and configuration drift. Comparing scan results before and after maintenance windows can verify that changes were applied correctly and did not introduce unintended exposures. Combined with firewall logging and an intrusion detection system, network scanning creates a layer of visibility that is difficult to replicate through other means and provides the documented evidence that compliance frameworks such as CMMC and PCI-DSS require as proof of network monitoring controls.